

The analyst's first stop for any indicator.

A free, public threat-intelligence console for a T1/T2 SOC analyst. Paste an IP, hash, URL, domain, CVE or email and get one screen back: a live multi-source reputation verdict, a ticket-ready escalation card, and one-click pivots to the services worth checking. Paste a PowerShell, cmd, mshta, or WSH command instead and the same box runs it through a deterministic, client-side decode-and-characterize pipeline — never executed, never leaving the browser. Zero infrastructure, zero cost, zero accounts.

Positioning. The heavyweight open-source CTI platforms (OpenCTI, MISP, IntelOwl) need servers and databases. SOCDesk sits deliberately beneath them: the zero-infra, public-URL, analyst-speed layer an analyst actually opens mid-shift.

OPERATING PRINCIPLES — CONSTANT ACROSS EVERY LEG

- **\$0, free-tier only.** No paid infra, no paid APIs beyond free community tiers.
- **No-infrastructure.** Static site + Cloudflare Pages Functions. No database, no server to run.
- **Aggregator, not mirror.** Publish only clearly-redistributable data; reputation corpora are reached by user-clicked links, never held.
- **No secrets in the repo.** Collectors are keyless; enrichment keys live server-side in Cloudflare, never in git or the browser.
- **Privacy by default.** Analyst state (reviewed, watchlist, notable) is localStorage only. No accounts, no analytics, no tracking.
- **Strict CSP + defence in depth.** `default-src 'none'`, no inline script; every upstream string sanitised at collection and escaped again at render.
- **RADAR visual direction.** Cool-slate ground, search-first, **periwinkle** accent + SD monogram; distinctive, not AI-slop. Live on **Vite + React + Tailwind + Motion** (strict CSP) — the legacy vanilla site/ build is superseded, kept in-repo for history only. (Chart Room superseded.)

LEG 1 · CURRENT SPRINT

01 INDICATOR LOOKUP, ESCALATION & ANALYZER

CORE · LIVE

The 99% workflow: paste an indicator → live reputation verdict → screenshot-grade evidence card → paste into the escalation email. Paste a PowerShell, cmd, mshta, or WSH command instead and the same box decodes and characterises it, deterministically and entirely client-side. One omnibox, two paths — this Leg is the product.

INPUT & DETECTION

- ✓ **Polymorphic cockpit** — one omnibox at / classifies an indicator vs. a command and routes inline (escalation card or analyzer) beside the 3D globe, which yields (dims + suspends its render loop) for the analyzer
- ✓ Type auto-detect + refang (IPv4, IPv6, domain, URL, MD5/SHA-1/SHA-256, CVE, email)
- ✓ **Shareable #q= deep links** for both /lookup and /analyzer — "look at this" is a URL, including a pasted command
- Bulk lookup (200 indicators, CSV/JSON/defanged export) + the in-context bookmarklet — `legacy site/ only, not yet rebuilt in web/`

LIVE ENRICHMENT · /API/ENRICH

- ✓ **IP** (incl. IPv6) → AbuseIPDB · VirusTotal · GreyNoise (IPv4-only) · ipinfo geo/ASN
- ✓ **Hash** → VirusTotal · MalwareBazaar
- ✓ **URL / domain** → VirusTotal · urlscan verdict + existing-scan screenshot · keyless RDAP registration age (domain)
- ✓ **Consensus tally** — "N of M sources flagged"; SOCDesk counts, never asserts a verdict

POWERSHELL / MULTI-INTERPRETER ANALYZER · /ANALYZER

- ✓ Deterministic, client-side decode ladder, never executes the input — `-enc Base64→UTF-16LE, gzip/raw-DEFLATE inflate, string-concat folding, single-assignment variable substitution, IEX/&-sink recursion`
- ✓ **Multi-interpreter** — detects and decodes `cmd.exe` (caret deobfuscation), `mshta`, and `wscript/cscript` (numeric char-code decode) alongside PowerShell, with depth-capped nested re-entry (`cmd /c powershell -enc ...` decodes the inner layer too) and always-on honesty signals when WSH/HTA coverage is thin
- ✓ IOC extraction across every decode layer, one-click "Look up →" pivot that resolves in place in the cockpit — no navigating away
- ✓ **17 MITRE ATT&CK-mapped signature rules** — download cradle, cmd-cradle/finger, evasion-flag cluster, AMSI reflection/memory-patch, ETW tamper, Defender tamper, ClickFix, beaconing, reverse shell, fileless loader, persistence, mshta/WSH execution, a 9-binary LOLBins table — with a co-occurrence upgrade
- ✓ **Specificity-gated characterization** — a RED "high-confidence malicious" callout only for intrinsically near-dispositive signals; an AMBER "suspicious" tier for corroborated co-occurrence; otherwise just the periwinkle technique tally. Never a synthesized score

OUTPUT — THE DIFFERENTIATOR

- ✓ **Escalation card** — a clean, factual artifact: source-class labels + per-source recency, signals as chips, no disclaimer prose. Copied as a PNG (**Copy card**) or **Copy text** — the analyst owns the nuance in the email
- ✓ **Compare-IP / impossible-travel** — great-circle miles + implied mph + an honest plausibility read, from real coordinates only, drawn as an arc on the globe and in the copy-card PNG
- ✓ **URL safe-view** — urlscan screenshot preview (click-to-expand) + a **Browserling** disposable-browser pivot; existing scans only, never submits
- ✓ Type-aware pivots, trimmed to the T1 workflow set (no fluff vendors)

REACH

- ✓ **Browser extension** (manifest v0.2.0) — the toolbar popup renders the same full **EscalationCard** as the web app, sharing detection + the enrich pipeline, so IPv6/RDAP/URL flow through
- Inline page annotation, broader selection-capture — `not built`

✓ `/analyzer#q=` deep-link prefill — a command routed from the palette or `/lookup` lands pre-filled and auto-analyzed

- The "explained" / kill-chain breakdown — a numbered, execution-ordered plain-English "what did it do" narrative (specced, not yet built)
- Deobfuscation breadth — `-join/-f/[char]/-replace/[Convert]::FromBase64String/.Invoke()` sink
- Technique-family expansion (credential access, ransomware, UAC bypass, lateral movement, DNS exfil), a wider LOLBin table (9 of ~200 L0LBAS), and a real entropy/honesty layer

LIVE at socdesk.io — the web/ React app (Vite + Tailwind + Motion) under a strict CSP; the legacy vanilla site/ app is superseded, kept in-repo for history. 138 vitest specs cover shared/analyzer. Verdict output is always a consensus tally or a gated characterization, never a synthesized score — see docs/VERDICT-LANGUAGE.md.

02 THREAT INTELLIGENCE FEED

CORE · SHARPEN, DON'T REBUILD

Situational awareness for the shift: what's happening, what's exploited, what's relevant to us. The pipeline and the /desk views are live in web / — per the owner's north star, Leg 2 stays dogfood-driven sharpening until Leg 1's loop is excellent, not a rewrite.

LIVE IN WEB/ TODAY

- ✓ **Collector pipeline** — KEV, NVD, EPSS, Ransomware.live, RSS pool; fault-isolated, schema-gated with last-known-good
- ✓ **Vulnerability triage** — full KEV catalogue joined with CVSS + EPSS, watchlist, KEV filter, sortable columns
- ✓ **Feed** — explainable 0–100 relevance score with a why per item
- ✓ **ATT&CK actor/malware profiles**, resolvable by name or alias, + the RELATED entity index
- ✓ **Collection health + source registry**

NEXT (P1 DOGFOOD FINDINGS + P2)

- **Reputation-quality fixes** — drop MalwareBazaar from IP cards, add AbuseIPDB abuse categories, surface the resolved A-record IP on domain cards
- **CVE patch/fixed-version + an "overdue" chip** when action-due < today; wire NVD_API_KEY
- **OTX AlienVault** as an enrich source; AbuseIPDB blacklist → an ambient reported-IP globe layer
- **Client / sector relevance filter** — the MSSP differentiator, unscheduled

Owner's north star (2026-08-10): the paste→reputation→email loop is 99% of a T1/T2 analyst's day, and everything else — CVE features included — is secondary until that loop is excellent. Live dogfood (2-3 analysts, a real shift) is the P1 gate before Leg 2 gets new construction.

03 LIVE ATTACK SENSOR — KNOCKKNOCK.NET-STYLE

FUTURE · GATED

SOCDesk stops being only an aggregator and starts producing first-party intelligence: our own honeypot sensors observing real attacks, published as a live feed that loops back into Legs 1 & 2.

CORE FUNCTIONS

- **Own honeypot sensor(s)** — Cowrie-class, capturing live SSH/Telnet/scan activity
- **Live attack telemetry & globe visualisation** (mockup: [design/mockups/h-sensor.html](#))
- **First-party IOC feed** — observed attacker infrastructure, feeding Leg-1 verdicts and Leg-2 feed
- **Trend surfacing** — emerging scan campaigns, credential-spray patterns

SECURITY NON-NEGOTIABLES

- **No Tailscale on the sensor** — no path from the honeypot into the tailnet
- **Cloud-plane egress deny** by default
- **Publish /24s, not full IPs** — no doxxing of compromised hosts
- **Allowlist published tokens**; rebuild from cloud-init, never snapshots

GATE

- ▶ **Resolve the employer-IP-assignment question first** — it gates this Leg (and the repo-private decision)

SEQUENCING & CURRENT STATUS

- ✓ **Done:** Leg 1 is LIVE at socdesk.io on the web/ React app — the polymorphic cockpit, multi-source enrichment + Compare-IP + URL safe-view, the escalation card, the browser extension at full-card parity, and the PowerShell/multi-interpreter analyzer (PowerShell, cmd, mshta, WSH) with 17 signature rules and specificity-gated characterization. Verified live 2026-08-19.
- ▶ **Now:** P1 — hammer the loop. Live dogfood (2-3 analysts, a real shift), the reputation-quality fixes from the UX/SOC review, and the analyzer's "explained" kill-chain narrative are next up.
- **Then:** P2 — sharpen Leg 2 (CVE patch/overdue chips, OTX, client-relevance filter) once the loop is excellent; the analyst-utility expansion lane (a vetted command-line deobfuscator, universal decoder, event-ID/ATT&CK lookup, a curated KQL query library) as an additive, accuracy-gated lane behind it.
- **Later:** Leg 3 sensor, gated on the employer-IP-assignment question.

04 HOSTING & CI/CD

AS SHIPPED

Two app trees live in the repo. `web/` — Vite + React + TS + Tailwind + Motion — is **what serves socdesk.io today**, built and deployed by CI on every run. `site/`, the legacy vanilla ES-module app, is superseded and kept in-repo for history only; it is no longer part of the deploy path.

HOST & DEPLOY METHOD

- ✓ **Cloudflare Pages**, project socdesk, domain socdesk.io
- ✓ **Direct Upload** via cloudflare/wrangler-action@v3 — deliberately *not* the Git integration
- ✓ **Why not Git integration**: free-plan builds are capped at **500/mo**; this workflow deploys **~1,440x/mo** (twice hourly). Direct uploads don't count against the cap
- ✓ **Repo stays private** — Cloudflare never needs read access to the source
- ✓ **Production vs preview routing** keyed on `--branch=${vars.CF_PRODUCTION_BRANCH} || 'main' }`

WORKFLOW · .GITHUB/WORKFLOWS/COLLECT-AND-DEPLOY.YML

- ✓ **Triggers**: `cron 11,41 * * * *` · workflow_dispatch · push to main touching `data/brief.json`
- ✓ **Steps**: checkout → setup-python 3.12 → pip install → pytest tests/ → python run_pipeline.py (dual-writes `site/data + data/state + web/public/data/state`) → commit `data/state` + pull-rebase-push → setup Node 20 → npm ci + vite build in `web/` → wrangler pages deploy `web/dist`
- ✓ **No self-trigger loop**: the state commit uses GITHUB_TOKEN, whose pushes can't retrigger Actions
- ✓ **Intentional asymmetry**: the Framework's `brief.json` pushes use a deploy key, so *those* DO trigger this workflow

```
deploy → wrangler pages deploy web/dist --project-name=socdesk --branch=${{
vars.CF_PRODUCTION_BRANCH || 'main' }}
```

Cloudflare Pages Functions are read from the repo-root `functions/` dir (project-root-relative, not deploy-dir-relative), so `/api/enrich` co-deploys alongside `web/dist` without a separate step. The Cloudflare "documented example" `githubToken/deployments-write` path is deliberately omitted — at ~1,440 runs/mo it would file that many GitHub Deployment records.

05 DATA FLOW & ENRICHMENT

AS SHIPPED

Git is the datastore — one small JSON file per payload, per day. All collectors are keyless/public; the only secrets in the system are the enrichment API keys, held server-side in Cloudflare.

PIPELINE OUTPUT · RUN_PIPELINE.PY

- ✓ `run(...)` dual-writes each payload to `site/data`, `data/state`, and `web/public/data/state` — the target the deployed web/ app fetches at runtime
- ✓ Rolling `data/state/*.json` (+ history/ series) are committed each run — last-known-good survives an upstream outage
- ✓ Payloads: `feed` · `cves` · `health` · `actors` · `malware` · `relations` · `sources` · `trends`; `brief.json` passed through if present (Tier 2)
- ✓ **No IOC corpus published** — reputation data is reached by user-clicked deep links or the same-origin enrich function at render, never mirrored (COMPLIANCE.md)

ENRICHMENT FUNCTION · /API/ENRICH

- ✓ **Cloudflare Pages Function** at `functions/api/enrich.js` → logic in `lib/enrich.mjs`
- ✓ **Types:** `ipv4` · `ipv6` · `domain` · `url` · `md5` · `sha1` · `sha256`
- ✓ **Sources:** AbuseIPDB · VirusTotal · GreyNoise (IPv4-only) · MalwareBazaar · `ipinfo` · `urlscan` · keyless **RDAP** (domain registration age)
- ✓ **Same-origin by design** — a Function on the site's own domain keeps CSP `connect-src 'self'`; no `api.*` origin, no CORS layer
- ✓ **Keys in Pages project secrets** (`ABUSEIPDB_API_KEY` · `VIRUSTOTAL` · `GREYNOISE_API_KEY` · `IPINFO_TOKEN` · `URLSCAN_API_KEY`) — never in git or the browser; MalwareBazaar and RDAP are keyless

```
collectors (keyless) → run_pipeline.py → site/data + data/state + web/public/data/state → vite
build → wrangler deploy web/dist → socdesk.io · browser → /api/enrich → AbuseIPDB / VT /
GreyNoise / MalwareBazaar / ipinfo / urlscan / RDAP
```

CONTENT-SECURITY-POLICY & HEADERS

- ✓ **Strict CSP, no inline anything.** Core across both trees: `default-src 'none'; script-src 'self'; style-src 'self'`
- ✓ **Live (web/public/_headers)** extends it with `img-src 'self' data: https://urlscan.io` (the one third-party exception, for the urlscan screenshot preview), `font-src 'self', connect-src 'self', worker/manifest-src 'self', base-uri/form-action/object-src 'none', frame-ancestors 'none', upgrade-insecure-requests` — plus `Permissions-Policy, COOP, X-Frame-Options: DENY`
- ✓ **web/public/_redirects** — `/* /index.html 200`, the SPA deep-link fallback for the path router (`/lookup · /desk · /actor · /analyzer`); Functions and static assets match first
- ✓ **Keys never reach the browser; collectors carry none.** Analyst state is `localStorage` only — no accounts, no analytics

PALETTE — INTENTIONALLY DIVERGENT

- ✓ **web/ is cool-slate** (`shared/tokens.css`) — the old warm-espresso ground clashed with the periwinkle accent
- ✓ **site/ (legacy) + the Copy-card PNG stay WARM** (`site/css/tokens.css` **RADAR** + `drawVerdict`) — deliberately divergent; `site/` is history-only, so this is a closed decision, not a pending flip
- ✓ One token source feeds the web app + the extension (`shared/tokens.css`) so those two can't drift

Role split held: cool/warm neutrals = the room; periwinkle = the product (never a verdict); red/amber/green = verdict & severity meaning only. The analyzer's one gated characterization callout is the sole place a verdict-severity hue appears in analyzer output — every technique chip stays periwinkle.

07

INFRASTRUCTURE

FOLLOW-UPS

The migration this section used to track — dual-write to `web/public/data/state`, the `_redirects` SPA fallback, the CI build step, and header parity — has shipped and is confirmed live (see §§04–06). What is left is opportunistic ops polish, non-blocking to the north-star loop.

CONCERN	CURRENT STATE	GAP	FIX
Copy-card PNG	urlscan screenshot renders on-card with a click-to-expand lightbox	Cross-origin urlscan image taints the copy canvas — the screenshot isn't composited into the PNG	Same-origin <code>/api/shot</code> proxy — not built
Preview env	Production Cloudflare Pages scope has all enrich keys set	Preview scope is still GreyNoise-only	Add the remaining enrich keys to the Preview scope
Deploy scripts	<code>tools/deploy-*.ps1</code> drive manual deploy/rollback	A PowerShell 5.1 quirk can report false success	Fix the false-success path — not yet done
Evidence-line visual	The ledger lists source, class, and recency as text	No per-source metric or icon	Visual pass — not built
Privacy contact	The privacy page ships a contact email	Address needs a currency check	Owner action — verify it's current

Deploy hygiene reminder, unchanged: the cron commits data: `refresh` snapshots constantly, so a plain `git push` is non-fast-forward — always `git pull --rebase origin main` first.